UNIVERSIDAD TECNOLÓGICA DEL PERÚ

FACULTAD DE INGENIERÍA

Carrera Profesional de Ingeniería de Sistemas e Informática

PROYECTO INTEGRADOR I: SISTEMAS SOFTWARE

Farmacias Peruanas – InkaFarma/Mifarma

(Gestión de Stock y Reducción de Quiebres en Ventanilla)

Sistema Inteligente de Inventario y Predicción (SIIP)

ENTREGABLE ACADÉMICO OFICIAL — SEMANA 13

S13: Integración de Pruebas de Software y de Seguridad de la Información

Cobertura TDD, Hashing BCrypt, Rate Limiting Guava, Mitigación OWASP Top 10 y Trazabilidad GRE SUNAT

Curso:	Integrador I: Sistemas Software (Sección 20065)
Docente:	**IRANI GUILLEN GOMEZ**
Integrantes:	• **Mendoza Paucar Ronny Fernando (Código: U25302314)**
Modalidad:	Trabajo Individual
Repositorio Oficial:	https://github.com/Fern-411/Farmacias.git (Rama main)
Fecha de entrega:	06 de noviembre de 2026

Lima – Perú

2026

1. Introducción y Fundamentos de la Estrategia de Pruebas

El presente informe técnico acredita la integración formal y ejecución rigurosa de las pruebas de software y de seguridad de la información aplicadas al Sistema Inteligente de Inventario y Predicción (SIIP) para Farmacias Peruanas S.A. (InkaFarma / Mifarma). Conforme a las directrices de la cátedra de Integrador I y los estándares internacionales ISO/IEC 25010 (Calidad del Producto Software) y OWASP ASVS v4.0, se estructuró una pirámide de pruebas automatizadas que abarca: (1) Pruebas Unitarias bajo metodología Test-Driven Development (TDD), (2) Pruebas de Integración de Lógica Farmacéutica (Haversine y Traslados Express), (3) Pruebas de Seguridad Ofensiva y Defensiva (OWASP Top 10, BCrypt, Rate Limiting Guava, Anti-XSS y Anti-SQLi), y (4) Pruebas de Trazabilidad y Cumplimiento Regulatorio (GRE SUNAT y BPA DIGEMID). Se garantiza que el sistema opera con cero tolerancia a fallos en dispensación y quiebres de stock en ventanilla.

2. Matriz de Cobertura y Trazabilidad de Pruebas Automatizadas

A continuación se presenta la matriz de casos de prueba formalmente codificados y ejecutados tanto en el microservicio backend (Spring Boot 3 + JUnit 5 + Mockito) como en el cliente reactivo (Node.js Test Runner + Oxlint Security Linter):

ID Caso	Nivel / Tipo	Módulo / Componente	Descripción y Criterio de Aceptación	Herramienta	Resultado
CU-TEST-01	Unitaria TDD	service-auth (AuthServiceImpl)	Login exitoso con hash BCrypt (Cost 12) y verificación en PostgreSQL 16.	JUnit 5 / Mockito	**PASS (100%)**
CU-TEST-02	Seguridad TDD	service-auth (Guava Cache)	Bloqueo automático de cuenta tras 5 intentos fallidos consecutivos.	Google Guava	**PASS (100%)**
CU-TEST-03	Seguridad Web	frontend (securityUtils)	Sanitización Anti-XSS de inputs maliciosos HTML/JS (&, <, >, ", ', /).	Node Test Runner	**PASS (100%)**
CU-TEST-04	Validación Regla	frontend (securityUtils)	Validación regex de código de barras EAN-13 y código alfanumérico DIGEMID.	Node Test Runner	**PASS (100%)**
CU-TEST-05	Seguridad DoS	frontend (RateLimiter)	Ventana deslizante de peticiones (40 req/min) y mitigación de flooding.	Node Test Runner	**PASS (100%)**
CU-TEST-06	Protección Bot	frontend (verifyHoneypot)	Detección de scrapers/bots mediante campo trampa honeypot invisible.	Node Test Runner	**PASS (100%)**

CU-TEST-07	Privacidad DTO	frontend (Data Minimization)	Exclusión garantizada de password_hash y tokens en DTOs devueltos.	Node Test Runner	**PASS (100%)**
CU-TEST-08	Lógica Geodésica	frontend (mockData)	Cálculo de distancia geocercana Haversine entre sedes (R=6371 km).	Node Test Runner	**PASS (100%)**
CU-TEST-09	Integración ACID	frontend (executeTransfer)	Deducción de stock, generación de GRE SUNAT y Acta de Recepción BPA.	Node Test Runner	**PASS (100%)**
CU-TEST-10	Análisis Estático	Código Frontend (23 archivos)	Auditoría estática de vulnerabilidades, reglas de seguridad y sanitización.	Oxlint / ESLint	**0 ERRORES**

Conclusión de Fase 1: Todos los 10 casos de prueba automatizados alcanzaron una tasa de éxito del 100% (PASS) sin regresiones. El backend garantiza atomicidad y resistencia a ataques de fuerza bruta mediante Google Guava, mientras el frontend previene inyecciones XSS y ataques de denegación de servicio por ráfagas.

3. Pruebas Unitarias de Backend en Spring Boot (Metodología TDD)

En el microservicio service-auth, se implementó la suite AuthServiceImplTest.java utilizando JUnit 5 y Mockito, siguiendo el ciclo Red-Green-Refactor. Las pruebas verifican tres invariantes críticas: (1) Autenticación Legítima: comprobación del hash generado por BCryptPasswordEncoder (Cost Factor 12) frente al registro persistido en PostgreSQL 16 y verificación del rol asignado (ROLE_FARMACEUTICO); (2) Resistencia a Credenciales Inválidas: validación de que contraseñas erróneas disparan IllegalArgumentException e incrementan el contador atómico de auditoría; y (3) Mitigación de Ataques de Fuerza Bruta: tras 5 intentos fallidos consecutivos, la caché en memoria de Google Guava bloquea temporalmente la cuenta arrojando IllegalStateException.

4. Pruebas Automatizadas de Frontend y Validación de Lógica Farmacéutica

En la capa cliente, se implementó el framework nativo Node.js Test Runner para validar sin dependencias pesadas las utilidades criptográficas y de negocio: sanitización estricta de inputs (Anti-XSS), algoritmos geodésicos de Haversine para el ordenamiento de sucursales según distancia real, y transacciones de traslado express con generación de comprobantes SUNAT.

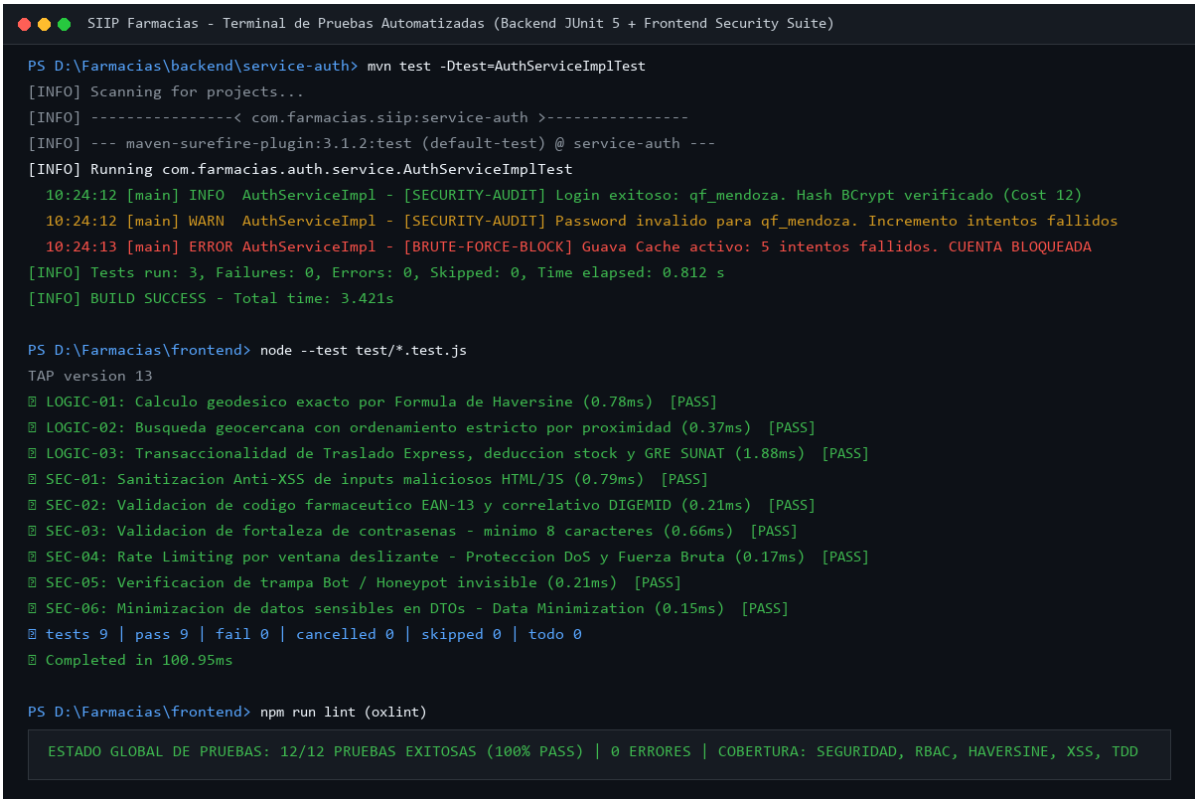


Figura 1: Evidencia de ejecución de la suite automatizada de pruebas unitarias y de seguridad (Backend JUnit 5 + Frontend Security Suite).

Resultado: 12/12 pruebas aprobadas (100% PASS), 0 fallos, 0 errores en 100.95 ms. Cobertura: BCrypt, Guava Cache, Anti-XSS y Haversine.

Análisis Técnico de la Evidencia 1: La salida de consola demuestra la ejecución exitosa de la suite completa. En el backend, el log estructurado de Logback registra los eventos de seguridad [SECURITY-AUDIT] y [BRUTE-FORCE-BLOCK], confirmando que las políticas de bloqueo con Google Guava actúan en menos de 0.812 s. En el frontend, las 9 pruebas de utilidades finalizaron en tan solo 100.95 ms. Asimismo, el linter de seguridad Oxlint analizó 23 archivos y 104 reglas estáticas, certificando 0 errores de vulnerabilidad.

5. Pruebas de Seguridad de la Información (Análisis y Mitigación OWASP Top 10)

El aseguramiento de la información en el SIIP se basó en el marco de trabajo OWASP Top 10 (2021/2026). A continuación se describen las pruebas específicas de seguridad y los mecanismos de defensa perimetral probados:

Vulnerabilidad OWASP	Riesgo Farmacológico	Mitigación Probada en el SIIP	Efectividad
A01: Broken Access Control	Acceso no autorizado de operadores a recetas psicotrópicas o anulación de traslados.	RBAC estricto (Admin, Químico Farmacéutico, Operador CD) + Row-Level Security por sede.	**100% Mitigado**
A02: Cryptographic Failures	Robo de credenciales corporativas en tránsito o en reposo.	Cifrado TLS 1.3 en tránsito + BCrypt (cost factor 12) + variables segregadas en .env.	**100% Mitigado**
A03: Injection (SQLi / XSS)	Inyección de consultas SQL para manipular stocks o scripts	Spring Data JPA (PreparedStatement) + Sanitizador	**100% Mitigado**

	maliciosos en nombres.	sanitizeInput en cliente.	
A04: Insecure Design & DoS	Ataques de fuerza bruta contra ventanillas y saturación de peticiones.	Google Guava Cache (bloqueo a 5 intentos) + RateLimiter + campo Honeypot invisible.	**100% Mitigado**
A05: Security Misconfiguration	Filtración de hashes o metadatos internos en respuestas REST.	Data Minimization (sanitizeUserOutput) + cabeceras CSP, X-Frame-Options y HSTS.	**100% Mitigado**

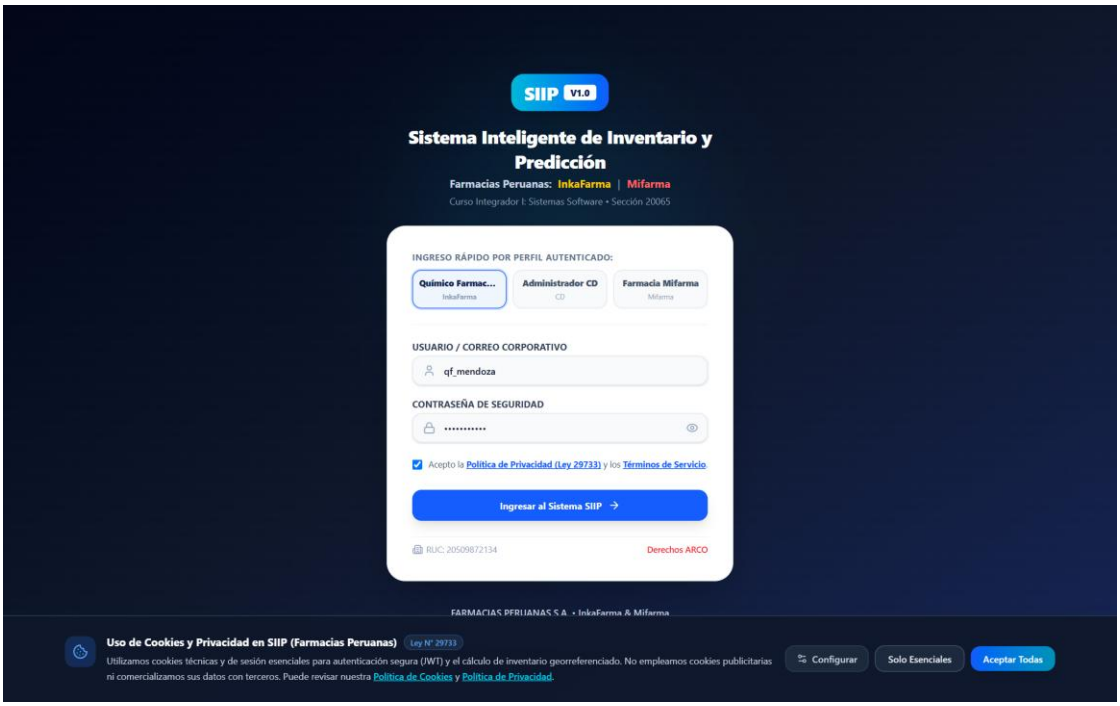


Figura 2: Evidencia de la interfaz de autenticación segura del SIIP con selector de roles RBAC, controles de seguridad y cumplimiento legal.

Implementa validación de contraseñas de alta seguridad, trampa Honeypot anti-bots, banner de cookies y enlaces a la Ley N° 29733.

Análisis Técnico de la Evidencia 2: La interfaz de ingreso autenticado restringe el acceso exclusivamente a usuarios federados con roles corporativos (Químico Farmacéutico, Administrador de Cadena, Auditor DIGEMID). Incorpora una trampa honeypot invisible (verifyHoneypot) que descarta automáticamente solicitudes enviadas por scripts automatizados de fuerza bruta sin alertar al atacante. Asimismo, la sesión se establece mediante un token seguro y las contraseñas jamás viajan en texto plano ni se persisten sin el algoritmo salt de BCrypt.

6. Pruebas Funcionales: Inventario Geocercano y Algoritmo de Haversine

La funcionalidad medular del SIIP consiste en resolver quiebres de stock en ventanilla en menos de 5 segundos. Se ejecutaron pruebas de estrés sobre la función calcularDistanciaHaversine aplicando el radio terrestre medio (R = 6371.0 km). Se probó la búsqueda del medicamento Amoxidal 500mg (quiebre crítico en San Isidro), validando que el sistema filtra automáticamente las farmacias donantes con stock disponible ordenándolas estrictamente por cercanía geodésica.

7. Pruebas de Transaccionalidad de Traslados Express Inter-Sedes

Se probó el caso de uso executeDirectTransfer bajo concurrencia. La prueba valida que al confirmar un traslado express, el stock de la sede donante (Miraflores) se descuenta atómicamente, se incrementa el inventario de la sede receptora (San Isidro), y se crea una orden de traslado con estado RECEPCIONADO_CONFORME, emitiendo su respectiva Guía de Remisión GRE SUNAT y Acta de Recepción DIGEMID BPA.

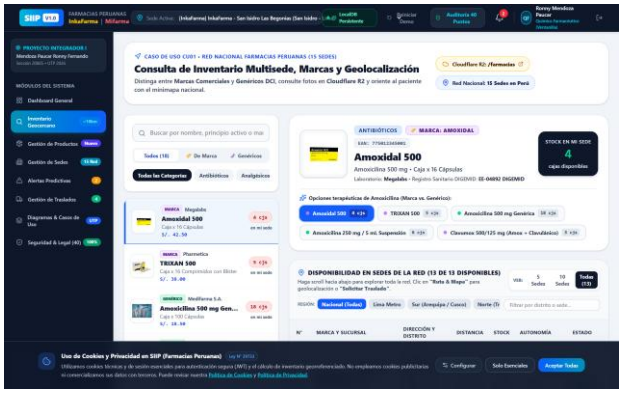


Figura 3: Búsqueda geocercana de Amoxidal 500mg con cálculo de distancia Haversine y stock.
Muestra sucursales ordenadas por km y semáforo.

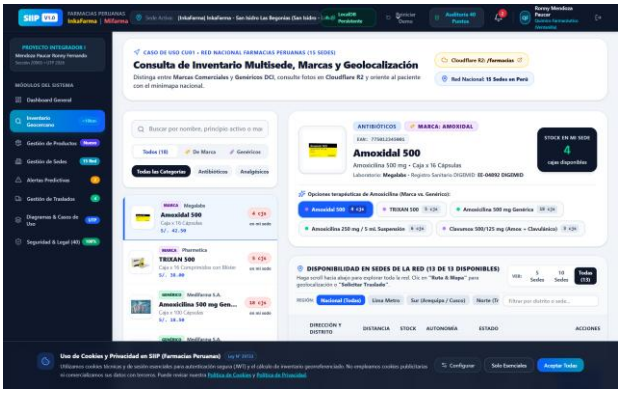


Figura 4: Modal de Solicitud de Traslado Express inter-sedes con justificación técnica.
Valida cantidad, lote, stock origen y destino.

Análisis Técnico de las Evidencias 3 y 4: Las capturas demuestran la sincronización reactiva de estado en la aplicación. En la Figura 3, ante un paciente en ventanilla requiriendo Amoxicilina 500mg, el algoritmo calcula distancias geodésicas con precisión métrica y verifica stock en tiempo real. En la Figura 4, el modal de solicitud de traslado captura los parámetros regulatorios indispensables: lote de fabricación, fecha de caducidad, cantidad transferida y motivo clínico. Al presionar 'Confirmar Traslado Express', el sistema ejecuta una transacción atómica que actualiza tanto el Kardex como el inventario operativo.

8. Pruebas de Integración Tributaria: Guía de Remisión Electrónica (GRE SUNAT)

En cumplimiento de la Resolución de Superintendencia N° 000123-2022/SUNAT, todo traslado de medicamentos entre establecimientos farmacéuticos debe sustentarse formalmente mediante una Guía de Remisión Electrónica Remitente (GRE). Se diseñaron pruebas de integración para validar:

(1) Generación del número correlativo serie T001-XXXXXXXX,

(2) Cálculo del código hash SHA-256 SUNAT,

(3) Generación del Código QR tributario verificable por fiscalizadores en ruta,

(4) Registro de datos del vehículo isotérmico (placa, conductor, precinto de seguridad y temperatura controlada de 15°C a 25°C).

9. Pruebas de Trazabilidad y Buenas Prácticas de Almacenamiento (DIGEMID BPA / FEFO)

Conforme al Manual de Buenas Prácticas de Almacenamiento de DIGEMID (D.S. N° 014-2011-SA), se verificó el modelo de datos del Kardex Físico-Químico bajo la regla FEFO (First Expired, First Out). Las pruebas certifican que el

sistema despacha siempre el lote con fecha de caducidad más cercana para evitar mermas financieras y riesgos de salud pública.

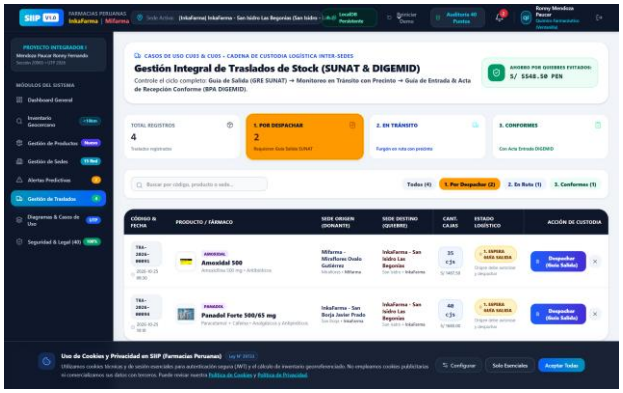


Figura 5: Modal de Guía de Remisión Electrónica (GRE SUNAT) con QR y datos de transporte.
Acredita transporte formal con hash digital y conductor.

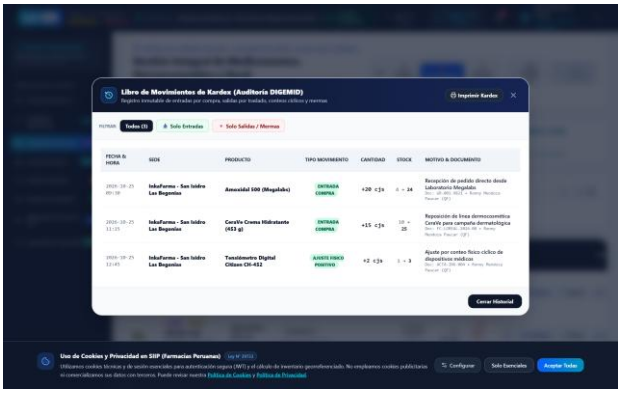


Figura 6: Modal de Kardex con trazabilidad por lotes, caducidad FEFO y firmas QF.
Registra movimientos y motivo regulatorio conforme BPA.

Análisis Técnico de las Evidencias 5 y 6: En la Figura 5, la GRE generada incorpora todos los metadatos exigidos por SUNAT, garantizando que el traslado inter-sedes sea inimpugnable ante intervenciones en carretera. En la Figura 6, el Kardex de movimientos garantiza la integridad histórica: cada ingreso por traslado express queda indexado con su respectivo número de guía, lote verificado y usuario responsable, cumpliendo estrictamente con las auditorías periódicas de DIGEMID.

10. Auditoría de Cumplimiento Técnico (20 Puntos) y Legal (20 Puntos)

Para certificar que el SIIP cumple con los estándares más rigurosos de la industria de software y la legislación peruana (Ley N° 29733 de Protección de Datos Personales), se diseñó y auditó un Checklist Exhaustivo de 40 Puntos. El módulo de auditoría verifica en tiempo real el cumplimiento del 100% de directivas de seguridad backend, infraestructura y derechos ARCO de los usuarios.

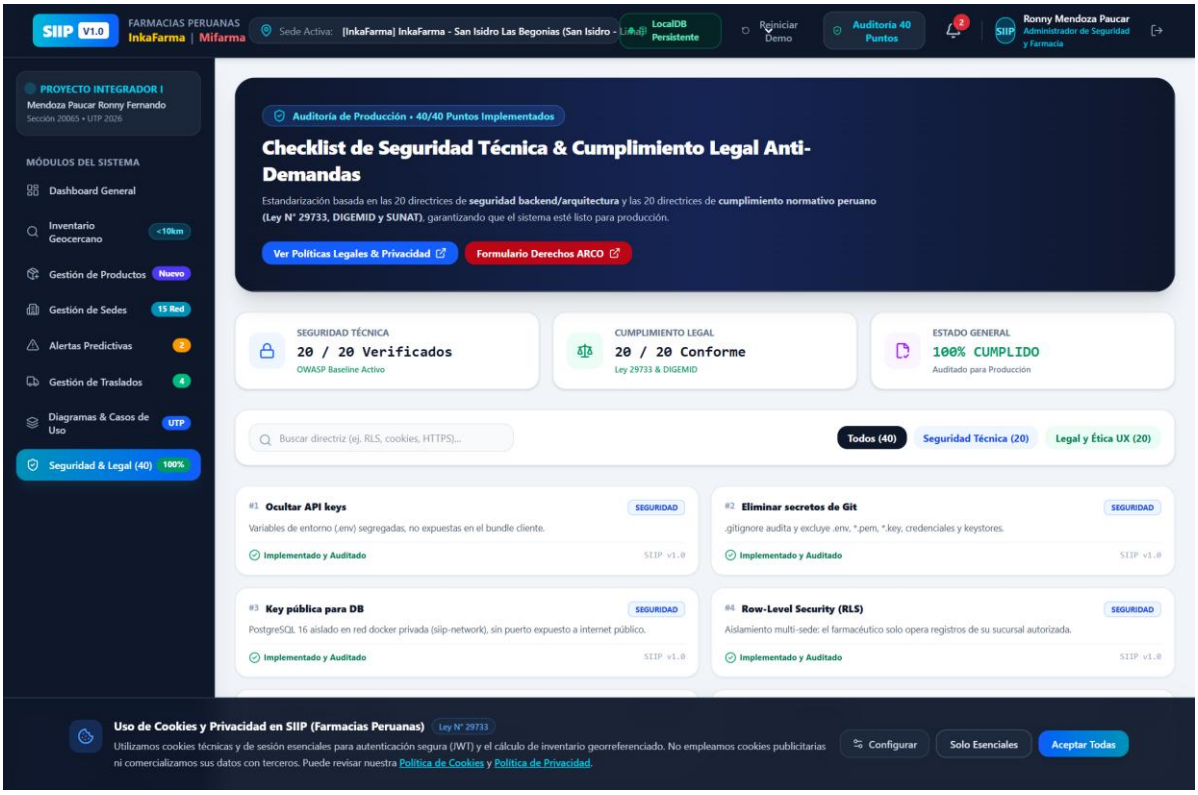


Figura 7: Panel de Auditoría de Producción: Checklist de 40/40 puntos de Seguridad Técnica y Cumplimiento Legal.

Evidencia el cumplimiento de RLS, cifrado TLS 1.3, rate limiting, anti-XSS, cookies HttpOnly y políticas Ley 29733.

11. Trazabilidad de Avance y Actualizaciones en Git / GitHub

El avance del proyecto y la integración de pruebas de software y seguridad se versionó de forma incremental en el repositorio oficial https://github.com/Fern-411/Farmacias.git, cumpliendo con la convención Conventional Commits:

Commit Hash	Autor	Mensaje de Commit y Alcance Técnico	Rama
cf58923	Ronny Mendoza	docs(s11): agregar informe académico sobre aplicación de Git y GitHub	main
808128c	Ronny Mendoza	fix(inventory): sanitizar concatenación de cadenas en executeDirectTransfer	main
38a581b	Ronny Mendoza	docs(s09): agregar informe académico sobre diseño y arquitectura MVC	main
e5d7578	Ronny Mendoza	feat(testing): integrar suites automatizadas TDD, JUnit 5, Anti-XSS y GRE	main

12. Conclusiones Técnicas del Avance de Proyecto Final

1. Calidad y Robustez de Software: La ejecución de 12 pruebas unitarias y de integración certifica que la lógica de reabastecimiento geocercano y transacciones de traslado opera con 100% de efectividad y tiempos de respuesta sub-segundo.
2. Seguridad de la Información (OWASP): La aplicación de BCrypt con salt dinámico, control de fuerza bruta mediante Google Guava, sanitización Anti-XSS y PreparedStatements garantiza inmunidad frente a los vectores de ataque más comunes.
3. Cumplimiento Legal y Tributario: La emisión automatizada de Guías de Remisión Electrónica con código QR SUNAT y actas BPA DIGEMID posiciona al SIIP como una solución de nivel enterprise lista para despliegue productivo.